4 Authenticator Assurance Levels

This section contains both normative and informative material.

To satisfy the requirements of a given AAL, a claimant SHALL be authenticated with at least a given level of strength to be recognized as a subscriber. The result of an authentication process is an identifier that SHALL be used each time that subscriber authenticates to that RP. The identifier MAY be pseudonymous. Subscriber identifiers SHOULD NOT be reused for a different subject but SHOULD be reused when a previously-enrolled subject is re-enrolled by the CSP. Other attributes that identify the subscriber as a unique subject MAY also be provided.

Detailed normative requirements for authenticators and verifiers at each AAL are provided in Section 5.

See SP 800-63 Section 6.2 for details on how to choose the most appropriate AAL.

FIPS 140 requirements are satisfied by FIPS 140-2 or newer revisions.

At IAL1, it is possible that attributes are collected and made available by the digital identity service. Any PII or other personal information — whether self-asserted or validated — requires multi-factor authentication. Therefore, agencies SHALL select a minimum of AAL2 when self-asserted PII or other personal information is made available online.

4.1 Authenticator Assurance Level 1

This section is normative.

AAL1 provides some assurance that the claimant controls an authenticator bound to the subscriber's account. AAL1 requires either single-factor or multi-factor authentication using a wide range of available authentication technologies. Successful authentication requires that the claimant prove possession and control of the authenticator through a secure authentication protocol.

4.1.1 Permitted Authenticator Types

AAL1 authentication SHALL occur by the use of any of the following authenticator types, which are defined in Section 5:

* Memorized Secret (Section 5.1.1)
* Look-Up Secret (Section 5.1.2)
* Out-of-Band Devices (Section 5.1.3)
* Single-Factor One-Time Password (OTP) Device (Section 5.1.4)
* Multi-Factor OTP Device (Section 5.1.5)
* Single-Factor Cryptographic Software (Section 5.1.6)
* Single-Factor Cryptographic Device (Section 5.1.7)
* Multi-Factor Cryptographic Software (Section 5.1.8)
* Multi-Factor Cryptographic Device (Section 5.1.9)

4.1.2 Authenticator and Verifier Requirements

Cryptographic authenticators used at AAL1 SHALL use approved cryptography. Software-based authenticators that operate within the context of an operating system MAY, where applicable,

attempt to detect compromise (e.g., by malware) of the user endpoint in which they are running and SHOULD NOT complete the operation when such a compromise is detected.

Communication between the claimant and verifier (using the primary channel in the case of an out-of-band authenticator) SHALL be via an authenticated protected channel to provide confidentiality of the authenticator output and resistance to man-in-the-middle (MitM) attacks.

Verifiers operated by government agencies at AAL1 SHALL be validated to meet the requirements of FIPS 140 Level 1.

4.1.3 Reauthentication

Periodic reauthentication of subscriber sessions SHALL be performed as described in Section 7.2. At AAL1, reauthentication of the subscriber SHOULD be repeated at least once per 30 days during an extended usage session, regardless of user activity. The session SHOULD be terminated (i.e., logged out) when this time limit is reached.

4.1.4 Security Controls

The CSP SHALL employ appropriately-tailored security controls from the *low* baseline of security controls defined in SP 800-53 or equivalent federal (e.g. FEDRAMP) or industry standard. The CSP SHALL ensure that the minimum assurance-related controls for *low-impact* systems, or equivalent, are satisfied.

4.1.5 Records Retention Policy

The CSP shall comply with its respective records retention policies in accordance with applicable laws, regulations, and policies, including any National Archives and Records Administration (NARA) records retention schedules that may apply. If the CSP opts to retain records in the absence of any mandatory requirements, the CSP SHALL conduct a risk management process, including assessments of privacy and security risks, to determine how long records should be retained and SHALL inform the subscriber of that retention policy.

4.2 Authenticator Assurance Level 2

This section is normative.

AAL2 provides high confidence that the claimant controls authenticator(s) bound to the subscriber's account. Proof of possession and control of two distinct authentication factors is required through secure authentication protocol(s). Approved cryptographic techniques are required at AAL2 and above.

4.2.1 Permitted Authenticator Types

At AAL2, authentication SHALL occur by the use of either a multi-factor authenticator or a combination of two single-factor authenticators. A multi-factor authenticator requires two factors to execute a single authentication event, such as a cryptographically-secure device with an integrated biometric sensor that is required to activate the device. Authenticator requirements are specified in Section 5.

When a multi-factor authenticator is used, any of the following MAY be used:

* Multi-Factor OTP Device (Section 5.1.5)
* Multi-Factor Cryptographic Software (Section 5.1.8)
* Multi-Factor Cryptographic Device (Section 5.1.9)

When a combination of two single-factor authenticators is used, it SHALL include a Memorized Secret authenticator (Section 5.1.1) and one possession-based (i.e., "something you have") authenticator from the following list:

* Look-Up Secret (Section 5.1.2)
* Out-of-Band Device (Section 5.1.3)
* Single-Factor OTP Device (Section 5.1.4)
* Single-Factor Cryptographic Software (Section 5.1.6)
* Single-Factor Cryptographic Device (Section 5.1.7)

Note: When biometric authentication meets the requirements in Section 5.2.3, the device has to be authenticated in addition to the biometric — a biometric is recognized as a factor, but not recognized as an authenticator by itself. Therefore, when conducting authentication with a biometric, it is unnecessary to use two authenticators because the associated device serves as "something you have," while the biometric serves as "something you are."

4.2.2 Authenticator and Verifier Requirements

Cryptographic authenticators used at AAL2 SHALL use approved cryptography. Authenticators procured by government agencies SHALL be validated to meet the requirements of FIPS 140 Level 1. Software-based authenticators that operate within the context of an operating system MAY, where applicable, attempt to detect compromise of the platform in which they are running (e.g., by malware) and SHOULD NOT complete the operation when such a compromise is detected. At least one authenticator used at AAL2 SHALL be replay resistant as described in Section 5.2.8. Authentication at AAL2 SHOULD demonstrate authentication intent from at least one authenticator as discussed in Section 5.2.9.

Communication between the claimant and verifier (the primary channel in the case of an out-of-band authenticator) SHALL be via an authenticated protected channel to provide confidentiality of the authenticator output and resistance to MitM attacks.

Verifiers operated by government agencies at AAL2 SHALL be validated to meet the requirements of FIPS 140 Level 1.

When a device such as a smartphone is used in the authentication process, the unlocking of that device (typically done using a PIN or biometric) SHALL NOT be considered one of the authentication factors. Generally, it is not possible for a verifier to know that the device had been locked or if the unlock process met the requirements for the relevant authenticator type.

When a biometric factor is used in authentication at AAL2, the performance requirements stated in Section 5.2.3 SHALL be met, and the verifier SHOULD make a determination that the biometric sensor and subsequent processing meet these requirements.

4.2.3 Reauthentication

Periodic reauthentication of subscriber sessions SHALL be performed as described in Section 7.2. At AAL2, authentication of the subscriber SHALL be repeated at least once per 12 hours during an extended usage session, regardless of user activity. Reauthentication of the subscriber SHALL be

repeated following any period of inactivity lasting 30 minutes or longer. The session SHALL be terminated (i.e., logged out) when either of these time limits is reached.

Reauthentication of a session that has not yet reached its time limit MAY require only a memorized secret or a biometric in conjunction with the still-valid session secret. The verifier MAY prompt the user to cause activity just before the inactivity timeout.

4.2.4 Security Controls

The CSP SHALL employ appropriately-tailored security controls from the *moderate* baseline of security controls defined in SP 800-53 or equivalent federal (e.g., FEDRAMP) or industry standard. The CSP SHALL ensure that the minimum assurance-related controls for *moderate-impact* systems or equivalent are satisfied.

4.2.5 Records Retention Policy

The CSP shall comply with its respective records retention policies in accordance with applicable laws, regulations, and policies, including any NARA records retention schedules that may apply. If the CSP opts to retain records in the absence of any mandatory requirements, the CSP SHALL conduct a risk management process, including assessments of privacy and security risks to determine how long records should be retained and SHALL inform the subscriber of that retention policy.

4.3 Authenticator Assurance Level 3

This section is normative.

AAL3 provides very high confidence that the claimant controls authenticator(s) bound to the subscriber's account. Authentication at AAL3 is based on proof of possession of a key through a cryptographic protocol. AAL3 authentication SHALL use a hardware-based authenticator and an authenticator that provides verifier impersonation resistance — the same device MAY fulfill both these requirements. In order to authenticate at AAL3, claimants SHALL prove possession and control of two distinct authentication factors through secure authentication protocol(s). Approved cryptographic techniques are required.

4.3.1 Permitted Authenticator Types

AAL3 authentication SHALL occur by the use of one of a combination of authenticators satisfying the requirements in Section 4.3. Possible combinations are:

* Multi-Factor Cryptographic Device (Section 5.1.9)
* Single-Factor Cryptographic Device (Section 5.1.7) used in conjunction with Memorized Secret (Section 5.1.1)
* Multi-Factor OTP device (software or hardware) (Section 5.1.5) used in conjunction with a Single-Factor Cryptographic Device (Section 5.1.7)
* Multi-Factor OTP device (hardware only) (Section 5.1.5) used in conjunction with a Single-Factor Cryptographic Software (Section 5.1.6)
* Single-Factor OTP device (hardware only) (Section 5.1.4) used in conjunction with a Multi-Factor Cryptographic Software Authenticator (Section 5.1.8)
* Single-Factor OTP device (hardware only) (Section 5.1.4) used in conjunction with a Single-Factor Cryptographic Software Authenticator (Section 5.1.6) and a Memorized Secret (Section 5.1.1)

4.3.2 Authenticator and Verifier Requirements

Communication between the claimant and verifier SHALL be via an authenticated protected channel to provide confidentiality of the authenticator output and resistance to MitM attacks. At least one cryptographic authenticator used at AAL3 SHALL be verifier impersonation resistant as described in Section 5.2.5 and SHALL be replay resistant as described in Section 5.2.8. All authentication and reauthentication processes at AAL3 SHALL demonstrate authentication intent from at least one authenticator as described in Section 5.2.9.

Multi-factor authenticators used at AAL3 SHALL be hardware cryptographic modules validated at FIPS 140 Level 2 or higher overall with at least FIPS 140 Level 3 physical security. Single-factor cryptographic devices used at AAL3 SHALL be validated at FIPS 140 Level 1 or higher overall with at least FIPS 140 Level 3 physical security.

Verifiers at AAL3 SHALL be validated at FIPS 140 Level 1 or higher.

Verifiers at AAL3 SHALL be verifier compromise resistant as described in Section 5.2.7 with respect to at least one authentication factor.

Hardware-based authenticators and verifiers at AAL3 SHOULD resist relevant side-channel (e.g., timing and power-consumption analysis) attacks. Relevant side-channel attacks SHALL be determined by a risk assessment performed by the CSP.

When a device such a smartphone is used in the authentication process — presuming that the device is able to meet the requirements above — the unlocking of that device SHALL NOT be considered to satisfy one of the authentication factors. This is because it is generally not possible for verifier to know that the device had been locked nor whether the unlock process met the requirements for the relevant authenticator type.

When a biometric factor is used in authentication at AAL3, the verifier SHALL make a determination that the biometric sensor and subsequent processing meet the performance requirements stated in Section 5.2.3.

4.3.3 Reauthentication

Periodic reauthentication of subscriber sessions SHALL be performed as described in Section 7.2. At AAL3, authentication of the subscriber SHALL be repeated at least once per 12 hours during an extended usage session, regardless of user activity, as described in Section 7.2. Reauthentication of the subscriber SHALL be repeated following any period of inactivity lasting 15 minutes or longer. Reauthentication SHALL use both authentication factors. The session SHALL be terminated (i.e., logged out) when either of these time limits is reached. The verifier MAY prompt the user to cause activity just before the inactivity timeout.

4.3.4 Security Controls

The CSP SHALL employ appropriately-tailored security controls from the *high* baseline of security controls defined in SP 800-53 or an equivalent federal (e.g., FEDRAMP) or industry standard. The CSP SHALL ensure that the minimum assurance-related controls for *high-impact* systems or equivalent are satisfied.

4.3.5 Records Retention Policy

The CSP shall comply with its respective records retention policies in accordance with applicable laws, regulations, and policies, including any NARA records retention schedules that may apply. If the CSP opts to retain records in the absence of any mandatory requirements, the CSP SHALL conduct a risk management process, including assessments of privacy and security risks, to determine how long records should be retained and SHALL inform the subscriber of that retention policy.

4.4 Privacy Requirements

The CSP SHALL employ appropriately-tailored privacy controls defined in SP 800-53 or equivalent industry standard.

If CSPs process attributes for purposes other than identity proofing, authentication, or attribute assertions (collectively "identity service"), related fraud mitigation, or to comply with law or legal process, CSPs SHALL implement measures to maintain predictability and manageability commensurate with the privacy risk arising from the additional processing. Measures MAY include providing clear notice, obtaining subscriber consent, or enabling selective use or disclosure of attributes. When CSPs use consent measures, CSPs SHALL NOT make consent for the additional processing a condition of the identity service.

Regardless of whether the CSP is an agency or private sector provider, the following requirements apply to an agency offering or using the authentication service:

1. The agency SHALL consult with their Senior Agency Official for Privacy (SAOP) and conduct an analysis to determine whether the collection of PII to issue or maintain authenticators triggers the requirements of the *Privacy Act of 1974* [Privacy Act] (see Section 9.4).
* The agency SHALL publish a System of Records Notice (SORN) to cover such collections, as applicable.
* The agency SHALL consult with their SAOP and conduct an analysis to determine whether the collection of PII to issue or maintain authenticators triggers the requirements of the *E-Government Act of 2002* [E-Gov].
* The agency SHALL publish a Privacy Impact Assessment (PIA) to cover such collection, as applicable.

4.5 Summary of Requirements

This section is informative.

Table 4-1 summarizes the requirements for each of the AALs:

Table 4-1 AAL Summary of Requirements

Requirement | AAL1 | AAL2 | AAL3

Permitted authenticator types | Memorized Secret;
Look-up Secret;
Out-of-Band;
SF OTP Device;
MF OTP Device;
SF Crypto Software;
SF Crypto Device;

MF Crypto Software;
MF Crypto Device
| MF OTP Device;
MF Crypto Software;
MF Crypto Device;
or Memorized Secret plus:
• Look-up Secret
• Out-of-Band
• SF OTP Device
• SF Crypto Software
• SF Crypto Device
| MF Crypto Device;
SF Crypto Device plus Memorized Secret;
SF OTP Device plus MF Crypto Device or Software;
SF OTP Device plus SF Crypto Software plus Memorized Secret
FIPS 140 validation | Level 1 (Government agency verifiers) | Level 1 (Government agency authenticators and verifiers) | Level 2 overall (MF authenticators)
Level 1 overall (verifiers and SF Crypto Devices)
Level 3 physical security (all authenticators)
Reauthentication | 30 days | 12 hours or 30 minutes inactivity; MAY use one authentication factor | 12 hours or 15 minutes inactivity; SHALL use both authentication factors
Security controls|SP 800-53 Low Baseline (or equivalent)|SP 800-53 Moderate Baseline (or equivalent)|SP 800-53 High Baseline (or equivalent)
MitM resistance | Required | Required | Required |
Verifier-impersonation resistance | Not required | Not required | Required |
Verifier-compromise resistance | Not required | Not required | Required |
Replay resistance | Not required | Required | Required |
Authentication intent | Not required | Recommended | Required |
Records Retention Policy | Required | Required | Required |
Privacy Controls | Required | Required | Required |

5 Authenticator and Verifier Requirements

This section is normative.

This section provides the detailed requirements specific to each type of authenticator. With the exception of reauthentication requirements specified in Section 4 and the requirement for verifier impersonation resistance at AAL3 described in Section 5.2.5, the technical requirements for each of the authenticator types are the same regardless of the AAL at which the authenticator is used.

5.1 Requirements by Authenticator Type

5.1.1 Memorized Secrets

|
A Memorized Secret authenticator — commonly referred to as a password or, if numeric, a PIN — is a secret value intended to be chosen and memorized by the user. Memorized secrets need to be of sufficient complexity and secrecy that it would be impractical for an attacker to guess or otherwise discover the correct secret value. A memorized secret is something you know. |

5.1.1.1 Memorized Secret Authenticators

Memorized secrets SHALL be at least 8 characters in length if chosen by the subscriber. Memorized secrets chosen randomly by the CSP or verifier SHALL be at least 6 characters in length and MAY be entirely numeric. If the CSP or verifier disallows a chosen memorized secret based on its appearance on a blacklist of compromised values, the subscriber SHALL be required to choose a different memorized secret. No other complexity requirements for memorized secrets SHOULD be imposed. A rationale for this is presented in Appendix A Strength of Memorized Secrets.

5.1.1.2 Memorized Secret Verifiers

Verifiers SHALL require subscriber-chosen memorized secrets to be at least 8 characters in length. Verifiers SHOULD permit subscriber-chosen memorized secrets at least 64 characters in length. All printing ASCII [RFC 20] characters as well as the space character SHOULD be acceptable in memorized secrets. Unicode [ISO/ISC 10646] characters SHOULD be accepted as well. To make allowances for likely mistyping, verifiers MAY replace multiple consecutive space characters with a single space character prior to verification, provided that the result is at least 8 characters in length. Truncation of the secret SHALL NOT be performed. For purposes of the above length requirements, each Unicode code point SHALL be counted as a single character.

If Unicode characters are accepted in memorized secrets, the verifier SHOULD apply the Normalization Process for Stabilized Strings using either the NFKC or NFKD normalization defined in Section 12.1 of Unicode Standard Annex 15 [UAX 15]. This process is applied before hashing the byte string representing the memorized secret. Subscribers choosing memorized secrets containing Unicode characters SHOULD be advised that some characters may be represented differently by some endpoints, which can affect their ability to authenticate successfully.

Memorized secrets that are randomly chosen by the CSP (e.g., at enrollment) or by the verifier (e.g., when a user requests a new PIN) SHALL be at least 6 characters in length and SHALL be generated using an approved random bit generator [SP 800-90Ar1].

Memorized secret verifiers SHALL NOT permit the subscriber to store a "hint" that is accessible to an unauthenticated claimant. Verifiers SHALL NOT prompt subscribers to use specific types of information (e.g., "What was the name of your first pet?") when choosing memorized secrets.

When processing requests to establish and change memorized secrets, verifiers SHALL compare the prospective secrets against a list that contains values known to be commonly-used, expected, or compromised. For example, the list MAY include, but is not limited to:

* Passwords obtained from previous breach corpuses.
* Dictionary words.
* Repetitive or sequential characters (e.g. 'aaaaaa', '1234abcd').
* Context-specific words, such as the name of the service, the username, and derivatives thereof.

If the chosen secret is found in the list, the CSP or verifier SHALL advise the subscriber that they need to select a different secret, SHALL provide the reason for rejection, and SHALL require the subscriber to choose a different value.

Verifiers SHOULD offer guidance to the subscriber, such as a password-strength meter [Meters], to assist the user in choosing a strong memorized secret. This is particularly important following the rejection of a memorized secret on the above list as it discourages trivial

modification of listed (and likely very weak) memorized secrets [Blacklists].

Verifiers SHALL implement a rate-limiting mechanism that effectively limits the number of failed authentication attempts that can be made on the subscriber's account as described in Section 5.2.2.

Verifiers SHOULD NOT impose other composition rules (e.g., requiring mixtures of different character types or prohibiting consecutively repeated characters) for memorized secrets. Verifiers SHOULD NOT require memorized secrets to be changed arbitrarily (e.g., periodically). However, verifiers SHALL force a change if there is evidence of compromise of the authenticator.

Verifiers SHOULD permit claimants to use "paste" functionality when entering a memorized secret. This facilitates the use of password managers, which are widely used and in many cases increase the likelihood that users will choose stronger memorized secrets.

In order to assist the claimant in successfully entering a memorized secret, the verifier SHOULD offer an option to display the secret — rather than a series of dots or asterisks — until it is entered. This allows the claimant to verify their entry if they are in a location where their screen is unlikely to be observed. The verifier MAY also permit the user's device to display individual entered characters for a short time after each character is typed to verify correct entry. This is particularly applicable on mobile devices.

The verifier SHALL use approved encryption and an authenticated protected channel when requesting memorized secrets in order to provide resistance to eavesdropping and MitM attacks.

Verifiers SHALL store memorized secrets in a form that is resistant to offline attacks. Memorized secrets SHALL be salted and hashed using a suitable one-way key derivation function. Key derivation functions take a password, a salt, and a cost factor as inputs then generate a password hash. Their purpose is to make each password guessing trial by an attacker who has obtained a password hash file expensive and therefore the cost of a guessing attack high or prohibitive. Examples of suitable key derivation functions include Password-based Key Derivation Function 2 (PBKDF2) [SP 800-132] and Balloon [BALLOON]. A memory-hard function SHOULD be used because it increases the cost of an attack. The key derivation function SHALL use an approved one-way function such as Keyed Hash Message Authentication Code (HMAC) [FIPS 198-1], any approved hash function in SP 800-107, Secure Hash Algorithm 3 (SHA-3) [FIPS 202], CMAC [SP 800-38B] or Keccak Message Authentication Code (KMAC), Customizable SHAKE (cSHAKE), or ParallelHash [SP 800-185]. The chosen output length of the key derivation function SHOULD be the same as the length of the underlying one-way function output.

The salt SHALL be at least 32 bits in length and be chosen arbitrarily so as to minimize salt value collisions among stored hashes. Both the salt value and the resulting hash SHALL be stored for each subscriber using a memorized secret authenticator.

For PBKDF2, the cost factor is an iteration count: the more times the PBKDF2 function is iterated, the longer it takes to compute the password hash. Therefore, the iteration count SHOULD be as large as verification server performance will allow, typically at least 10,000 iterations.

In addition, verifiers SHOULD perform an additional iteration of a key derivation function using a salt value that is secret and known only to the verifier. This salt value, if used, SHALL be generated by an approved random bit generator [SP 800-90Ar1] and provide at least the minimum security strength specified in the latest revision of SP 800-131A (112 bits as of the date of

this publication). The secret salt value SHALL be stored separately from the hashed memorized secrets (e.g., in a specialized device like a hardware security module). With this additional iteration, brute-force attacks on the hashed memorized secrets are impractical as long as the secret salt value remains secret.

5.1.2 Look-Up Secrets

|
A look-up secret authenticator is a physical or electronic record that stores a set of secrets shared between the claimant and the CSP. The claimant uses the authenticator to look up the appropriate secret(s) needed to respond to a prompt from the verifier. For example, the verifier may ask a claimant to provide a specific subset of the numeric or character strings printed on a card in table format. A common application of look-up secrets is the use of "recovery keys" stored by the subscriber for use in the event another authenticator is lost or malfunctions. A look-up secret is something you have. |

5.1.2.1 Look-Up Secret Authenticators CSPs creating look-up secret authenticators SHALL use an approved random bit generator [SP 800-90Ar1] to generate the list of secrets and SHALL deliver the authenticator securely to the subscriber. Look-up secrets SHALL have at least 20 bits of entropy.

Look-up secrets MAY be distributed by the CSP in person, by postal mail to the subscriber's address of record, or by online distribution. If distributed online, look-up secrets SHALL be distributed over a secure channel in accordance with the post-enrollment binding requirements in Section 6.1.2.

If the authenticator uses look-up secrets sequentially from a list, the subscriber MAY dispose of used secrets, but only after a successful authentication.

5.1.2.2 Look-Up Secret Verifiers

Verifiers of look-up secrets SHALL prompt the claimant for the next secret from their authenticator or for a specific (e.g., numbered) secret. A given secret from an authenticator SHALL be used successfully only once. If the look-up secret is derived from a grid card, each cell of the grid SHALL be used only once.

Verifiers SHALL store look-up secrets in a form that is resistant to offline attacks. Look-up secrets having at least 112 bits of entropy SHALL be hashed with an approved one-way function as described in Section 5.1.1.2. Look-up secrets with fewer than 112 bits of entropy SHALL be salted and hashed using a suitable one-way key derivation function, also described in Section 5.1.1.2. The salt value SHALL be at least 32 in bits in length and arbitrarily chosen so as to minimize salt value collisions among stored hashes. Both the salt value and the resulting hash SHALL be stored for each look-up secret.

For look-up secrets that have less than 64 bits of entropy, the verifier SHALL implement a rate-limiting mechanism that effectively limits the number of failed authentication attempts that can be made on the subscriber's account as described in Section 5.2.2.

The verifier SHALL use approved encryption and an authenticated protected channel when requesting look-up secrets in order to provide resistance to eavesdropping and MitM attacks.

5.1.3 Out-of-Band Devices

|
An out-of-band authenticator is a physical device that is uniquely addressable and can communicate securely with the verifier over a distinct communications channel, referred to as the secondary channel. The device is possessed and controlled by the claimant and supports private communication over this secondary channel, separate from the primary channel for e-authentication. An out-of-band authenticator is something you have.

The out-of-band authenticator can operate in one of the following ways:

- The claimant transfers a secret received by the out-of-band device via the secondary channel to the verifier using the primary channel. For example, the claimant may receive the secret on their mobile device and type it (typically a 6-digit code) into their authentication session.

- The claimant transfers a secret received via the primary channel to the out-of-band device for transmission to the verifier via the secondary channel. For example, the claimant may view the secret on their authentication session and either type it into an app on their mobile device or use a technology such as a barcode or QR code to effect the transfer.

- The claimant compares secrets received from the primary channel and the secondary channel and confirms the authentication via the secondary channel.

The secret's purpose is to securely bind the authentication operation on the primary and secondary channel. When the response is via the primary communication channel, the secret also establishes the claimant's control of the out-of-band device. |

5.1.3.1 Out-of-Band Authenticators

The out-of-band authenticator SHALL establish a separate channel with the verifier in order to retrieve the out-of-band secret or authentication request. This channel is considered to be out-of-band with respect to the primary communication channel (even if it terminates on the same device) provided the device does not leak information from one channel to the other without the authorization of the claimant.

The out-of-band device SHOULD be uniquely addressable and communication over the secondary channel SHALL be encrypted unless sent via the public switched telephone network (PSTN). For additional authenticator requirements specific to the PSTN, see Section 5.1.3.3. Methods that do not prove possession of a specific device, such as voice-over-IP (VOIP) or email, SHALL NOT be used for out-of-band authentication.

The out-of-band authenticator SHALL uniquely authenticate itself in one of the following ways when communicating with the verifier:

- Establish an authenticated protected channel to the verifier using approved cryptography. The key used SHALL be stored in suitably secure storage available to the authenticator application (e.g., keychain storage, TPM, TEE, secure element).

- Authenticate to a public mobile telephone network using a SIM card or equivalent that uniquely identifies the device. This method SHALL only be used if a secret is being sent from the verifier to the out-of-band device via the PSTN (SMS or voice).

If a secret is sent by the verifier to the out-of-band device, the device SHOULD NOT display the

authentication secret while it is locked by the owner (i.e., requires an entry of a PIN, passcode, or biometric to view). However, authenticators SHOULD indicate the receipt of an authentication secret on a locked device.

If the out-of-band authenticator sends an approval message over the secondary communication channel — rather than by the claimant transferring a received secret to the primary communication channel — it SHALL do one of the following:

* The authenticator SHALL accept transfer of the secret from the primary channel which it SHALL send to the verifier over the secondary channel to associate the approval with the authentication transaction. The claimant MAY perform the transfer manually or use a technology such as a barcode or QR code to effect the transfer.

* The authenticator SHALL present a secret received via the secondary channel from the verifier and prompt the claimant to verify the consistency of that secret with the primary channel, prior to accepting a yes/no response from the claimant. It SHALL then send that response to the verifier.

5.1.3.2 Out-of-Band Verifiers

For additional verification requirements specific to the PSTN, see Section 5.1.3.3.

If out-of-band verification is to be made using a secure application, such as on a smart phone, the verifier MAY send a push notification to that device. The verifier then waits for the establishment of an authenticated protected channel and verifies the authenticator's identifying key. The verifier SHALL NOT store the identifying key itself, but SHALL use a verification method (e.g., an approved hash function or proof of possession of the identifying key) to uniquely identify the authenticator. Once authenticated, the verifier transmits the authentication secret to the authenticator.

Depending on the type of out-of-band authenticator, one of the following SHALL take place:

* Transfer of secret to primary channel: The verifier MAY signal the device containing the subscriber's authenticator to indicate readiness to authenticate. It SHALL then transmit a random secret to the out-of-band authenticator. The verifier SHALL then wait for the secret to be returned on the primary communication channel.

* Transfer of secret to secondary channel: The verifier SHALL display a random authentication secret to the claimant via the primary channel. It SHALL then wait for the secret to be returned on the secondary channel from the claimant's out-of-band authenticator.

* Verification of secrets by claimant: The verifier SHALL display a random authentication secret to the claimant via the primary channel, and SHALL send the same secret to the out-of-band authenticator via the secondary channel for presentation to the claimant. It SHALL then wait for an approval (or disapproval) message via the secondary channel.

In all cases, the authentication SHALL be considered invalid if not completed within 10 minutes. In order to provide replay resistance as described in Section 5.2.8, verifiers SHALL accept a given authentication secret only once during the validity period.

The verifier SHALL generate random authentication secrets with at least 20 bits of entropy using an approved random bit generator [SP 800-90Ar1]. If the authentication secret has less than 64

bits of entropy, the verifier SHALL implement a rate-limiting mechanism that effectively limits the number of failed authentication attempts that can be made on the subscriber's account as described in Section 5.2.2.

5.1.3.3 Authentication using the Public Switched Telephone Network

Use of the PSTN for out-of-band verification is RESTRICTED as described in this section and in Section 5.2.10. If out-of-band verification is to be made using the PSTN, the verifier SHALL verify that the pre-registered telephone number being used is associated with a specific physical device. Changing the pre-registered telephone number is considered to be the binding of a new authenticator and SHALL only occur as described in Section 6.1.2.

Verifiers SHOULD consider risk indicators such as device swap, SIM change, number porting, or other abnormal behavior before using the PSTN to deliver an out-of-band authentication secret.

NOTE: Consistent with the restriction of authenticators in Section 5.2.10, NIST may adjust the RESTRICTED status of the PSTN over time based on the evolution of the threat landscape and the technical operation of the PSTN.

5.1.4 Single-Factor OTP Device

|
A single-factor OTP device generates OTPs. This category includes hardware devices and software-based OTP generators installed on devices such as mobile phones. These devices have an embedded secret that is used as the seed for generation of OTPs and does not require activation through a second factor. The OTP is displayed on the device and manually input for transmission to the verifier, thereby proving possession and control of the device. An OTP device may, for example, display 6 characters at a time. A single-factor OTP device is something you have.

Single-factor OTP devices are similar to look-up secret authenticators with the exception that the secrets are cryptographically and independently generated by the authenticator and verifier and compared by the verifier. The secret is computed based on a nonce that may be time-based or from a counter on the authenticator and verifier. |

5.1.4.1 Single-Factor OTP Authenticators

Single-factor OTP authenticators contain two persistent values. The first is a symmetric key that persists for the device's lifetime. The second is a nonce that is either changed each time the authenticator is used or is based on a real-time clock.

The secret key and its algorithm SHALL provide at least the minimum security strength specified in the latest revision of SP 800-131A (112 bits as of the date of this publication). The nonce SHALL be of sufficient length to ensure that it is unique for each operation of the device over its lifetime. OTP authenticators — particularly software-based OTP generators — SHOULD discourage and SHALL NOT facilitate the cloning of the secret key onto multiple devices.

The authenticator output is obtained by using an approved block cipher or hash function to combine the key and nonce in a secure manner. The authenticator output MAY be truncated to as few as 6 decimal digits (approximately 20 bits of entropy).

If the nonce used to generate the authenticator output is based on a real-time clock, the nonce

SHALL be changed at least once every 2 minutes. The OTP value associated with a given nonce SHALL be accepted only once.

5.1.4.2 Single-Factor OTP Verifiers

Single-factor OTP verifiers effectively duplicate the process of generating the OTP used by the authenticator. As such, the symmetric keys used by authenticators are also present in the verifier, and SHALL be strongly protected against compromise.

When a single-factor OTP authenticator is being associated with a subscriber account, the verifier or associated CSP SHALL use approved cryptography to either generate and exchange or to obtain the secrets required to duplicate the authenticator output.

The verifier SHALL use approved encryption and an authenticated protected channel when collecting the OTP in order to provide resistance to eavesdropping and MitM attacks. Time-based OTPs [RFC 6238] SHALL have a defined lifetime that is determined by the expected clock drift — in either direction — of the authenticator over its lifetime, plus allowance for network delay and user entry of the OTP. In order to provide replay resistance as described in Section 5.2.8, verifiers SHALL accept a given time-based OTP only once during the validity period.

If the authenticator output has less than 64 bits of entropy, the verifier SHALL implement a rate-limiting mechanism that effectively limits the number of failed authentication attempts that can be made on the subscriber's account as described in Section 5.2.2.

5.1.5 Multi-Factor OTP Devices

|
A multi-factor OTP device generates OTPs for use in authentication after activation through an additional authentication factor. This includes hardware devices and software-based OTP generators installed on devices such as mobile phones. The second factor of authentication may be achieved through some kind of integral entry pad, an integral biometric (e.g., fingerprint) reader, or a direct computer interface (e.g., USB port). The OTP is displayed on the device and manually input for transmission to the verifier. For example, an OTP device may display 6 characters at a time, thereby proving possession and control of the device. The multi-factor OTP device is something you have, and it SHALL be activated by either something you know or something you are. |

5.1.5.1 Multi-Factor OTP Authenticators

Multi-factor OTP authenticators operate in a similar manner to single-factor OTP authenticators (see Section 5.1.4.1), except that they require the entry of either a memorized secret or the use of a biometric to obtain the OTP from the authenticator. Each use of the authenticator SHALL require the input of the additional factor.

In addition to activation information, multi-factor OTP authenticators contain two persistent values. The first is a symmetric key that persists for the device's lifetime. The second is a nonce that is either changed each time the authenticator is used or is based on a real-time clock.

The secret key and its algorithm SHALL provide at least the minimum security strength specified in the latest revision of [SP 800-131A] (112 bits as of the date of this publication). The nonce SHALL be of sufficient length to ensure that it is unique for each operation of the device over

its lifetime. OTP authenticators — particularly software-based OTP generators — SHOULD discourage and SHALL NOT facilitate the cloning of the secret key onto multiple devices.

The authenticator output is obtained by using an approved block cipher or hash function to combine the key and nonce in a secure manner. The authenticator output MAY be truncated to as few as 6 decimal digits (approximately 20 bits of entropy).

If the nonce used to generate the authenticator output is based on a real-time clock, the nonce SHALL be changed at least once every 2 minutes. The OTP value associated with a given nonce SHALL be accepted only once.

Any memorized secret used by the authenticator for activation SHALL be a randomly-chosen numeric secret at least 6 decimal digits in length or other memorized secret meeting the requirements of Section 5.1.1.2 and SHALL be rate limited as specified in Section 5.2.2. A biometric activation factor SHALL meet the requirements of Section 5.2.3, including limits on the number of consecutive authentication failures.

The unencrypted key and activation secret or biometric sample — and any biometric data derived from the biometric sample such as a probe produced through signal processing — SHALL be zeroized immediately after an OTP has been generated.

5.1.5.2 Multi-Factor OTP Verifiers

Multi-factor OTP verifiers effectively duplicate the process of generating the OTP used by the authenticator, but without the requirement that a second factor be provided. As such, the symmetric keys used by authenticators SHALL be strongly protected against compromise.

When a multi-factor OTP authenticator is being associated with a subscriber account, the verifier or associated CSP SHALL use approved cryptography to either generate and exchange or to obtain the secrets required to duplicate the authenticator output. The verifier or CSP SHALL also establish, via the authenticator source, that the authenticator is a multi-factor device. In the absence of a trusted statement that it is a multi-factor device, the verifier SHALL treat the authenticator as single-factor, in accordance with Section 5.1.4.

The verifier SHALL use approved encryption and an authenticated protected channel when collecting the OTP in order to provide resistance to eavesdropping and MitM attacks. Time-based OTPs [RFC 6238] SHALL have a defined lifetime that is determined by the expected clock drift — in either direction — of the authenticator over its lifetime, plus allowance for network delay and user entry of the OTP. In order to provide replay resistance as described in Section 5.2.8, verifiers SHALL accept a given time-based OTP only once during the validity period. In the event a claimant's authentication is denied due to duplicate use of an OTP, verifiers MAY warn the claimant in case an attacker has been able to authenticate in advance. Verifiers MAY also warn a subscriber in an existing session of the attempted duplicate use of an OTP.

If the authenticator output or activation secret has less than 64 bits of entropy, the verifier SHALL implement a rate-limiting mechanism that effectively limits the number of failed authentication attempts that can be made on the subscriber's account as described in Section 5.2.2. A biometric activation factor SHALL meet the requirements of Section 5.2.3, including limits on the number of consecutive authentication failures.

5.1.6 Single-Factor Cryptographic Software

|
A single-factor software cryptographic authenticator is a cryptographic key stored on disk or some other "soft" media. Authentication is accomplished by proving possession and control of the key. The authenticator output is highly dependent on the specific cryptographic protocol, but it is generally some type of signed message. The single-factor software cryptographic authenticator is something you have. |

5.1.6.1 Single-Factor Cryptographic Software Authenticators

Single-factor software cryptographic authenticators encapsulate one or more secret keys unique to the authenticator. The key SHALL be stored in suitably secure storage available to the authenticator application (e.g., keychain storage, TPM, or TEE if available). The key SHALL be strongly protected against unauthorized disclosure by the use of access controls that limit access to the key to only those software components on the device requiring access. Single-factor cryptographic software authenticators SHOULD discourage and SHALL NOT facilitate the cloning of the secret key onto multiple devices.

5.1.6.2 Single-Factor Cryptographic Software Verifiers

The requirements for a single-factor cryptographic software verifier are identical to those for a single-factor cryptographic device verifier, described in Section 5.1.7.2.

5.1.7 Single-Factor Cryptographic Devices

|
A single-factor cryptographic device is a hardware device that performs cryptographic operations using protected cryptographic key(s) and provides the authenticator output via direct connection to the user endpoint. The device uses embedded symmetric or asymmetric cryptographic keys, and does not require activation through a second factor of authentication. Authentication is accomplished by proving possession of the device via the authentication protocol. The authenticator output is provided by direct connection to the user endpoint and is highly dependent on the specific cryptographic device and protocol, but it is typically some type of signed message. A single-factor cryptographic device is something you have. |

5.1.7.1 Single-Factor Cryptographic Device Authenticators

Single-factor cryptographic device authenticators encapsulate one or more secret keys unique to the device that SHALL NOT be exportable (i.e., cannot be removed from the device). The authenticator operates by signing a challenge nonce presented through a direct computer interface (e.g., a USB port). Alternatively, the authenticator could be a suitably secure processor integrated with the user endpoint itself (e.g., a hardware TPM). Although cryptographic devices contain software, they differ from cryptographic software authenticators in that all embedded software is under control of the CSP or issuer and that the entire authenticator is subject to all applicable FIPS 140 requirements at the AAL being authenticated.

The secret key and its algorithm SHALL provide at least the minimum security length specified in the latest revision of SP 800-131A (112 bits as of the date of this publication). The challenge nonce SHALL be at least 64 bits in length. Approved cryptography SHALL be used.

Single-factor cryptographic device authenticators SHOULD require a physical input (e.g., the pressing of a button) in order to operate. This provides defense against unintended operation of the device, which might occur if the endpoint to which it is connected is compromised.

5.1.7.2 Single-Factor Cryptographic Device Verifiers

Single-factor cryptographic device verifiers generate a challenge nonce, send it to the corresponding authenticator, and use the authenticator output to verify possession of the device. The authenticator output is highly dependent on the specific cryptographic device and protocol, but it is generally some type of signed message.

The verifier has either symmetric or asymmetric cryptographic keys corresponding to each authenticator. While both types of keys SHALL be protected against modification, symmetric keys SHALL additionally be protected against unauthorized disclosure.

The challenge nonce SHALL be at least 64 bits in length, and SHALL either be unique over the authenticator's lifetime or statistically unique (i.e., generated using an approved random bit generator [SP 800-90Ar1]). The verification operation SHALL use approved cryptography.

5.1.8 Multi-Factor Cryptographic Software

|
A multi-factor software cryptographic authenticator is a cryptographic key stored on disk or some other "soft" media that requires activation through a second factor of authentication. Authentication is accomplished by proving possession and control of the key. The authenticator output is highly dependent on the specific cryptographic protocol, but it is generally some type of signed message. The multi-factor software cryptographic authenticator is something you have, and it SHALL be activated by either something you know or something you are. |

5.1.8.1 Multi-Factor Cryptographic Software Authenticators

Multi-factor software cryptographic authenticators encapsulate one or more secret keys unique to the authenticator and accessible only through the input of an additional factor, either a memorized secret or a biometric. The key SHOULD be stored in suitably secure storage available to the authenticator application (e.g., keychain storage, TPM, TEE). The key SHALL be strongly protected against unauthorized disclosure by the use of access controls that limit access to the key to only those software components on the device requiring access. Multi-factor cryptographic software authenticators SHOULD discourage and SHALL NOT facilitate the cloning of the secret key onto multiple devices.

Each authentication operation using the authenticator SHALL require the input of both factors.

Any memorized secret used by the authenticator for activation SHALL be a randomly-chosen numeric value at least 6 decimal digits in length or other memorized secret meeting the requirements of Section 5.1.1.2 and SHALL be rate limited as specified in Section 5.2.2. A biometric activation factor SHALL meet the requirements of Section 5.2.3, including limits on the number of consecutive authentication failures.

The unencrypted key and activation secret or biometric sample — and any biometric data derived from the biometric sample such as a probe produced through signal processing — SHALL be zeroized immediately after an authentication transaction has taken place.

5.1.8.2 Multi-Factor Cryptographic Software Verifiers

The requirements for a multi-factor cryptographic software verifier are identical to those for a

single-factor cryptographic device verifier, described in Section 5.1.7.2. Verification of the output from a multi-factor cryptographic software authenticator proves use of the activation factor.

5.1.9 Multi-Factor Cryptographic Devices

|
A multi-factor cryptographic device is a hardware device that performs cryptographic operations using one or more protected cryptographic keys and requires activation through a second authentication factor. Authentication is accomplished by proving possession of the device and control of the key. The authenticator output is provided by direct connection to the user endpoint and is highly dependent on the specific cryptographic device and protocol, but it is typically some type of signed message. The multi-factor cryptographic device is something you have, and it SHALL be activated by either something you know or something you are. |

5.1.9.1 Multi-Factor Cryptographic Device Authenticators

Multi-factor cryptographic device authenticators use tamper-resistant hardware to encapsulate one or more secret keys unique to the authenticator and accessible only through the input of an additional factor, either a memorized secret or a biometric. The authenticator operates by using a private key that was unlocked by the additional factor to sign a challenge nonce presented through a direct computer interface (e.g., a USB port). Alternatively, the authenticator could be a suitably secure processor integrated with the user endpoint itself (e.g., a hardware TPM). Although cryptographic devices contain software, they differ from cryptographic software authenticators in that all embedded software is under control of the CSP or issuer, and that the entire authenticator is subject to any applicable FIPS 140 requirements at the selected AAL.

The secret key and its algorithm SHALL provide at least the minimum security length specified in the latest revision of SP 800-131A (112 bits as of the date of this publication). The challenge nonce SHALL be at least 64 bits in length. Approved cryptography SHALL be used.

Each authentication operation using the authenticator SHOULD require the input of the additional factor. Input of the additional factor MAY be accomplished via either direct input on the device or via a hardware connection (e.g., USB, smartcard).

Any memorized secret used by the authenticator for activation SHALL be a randomly-chosen numeric value at least 6 decimal digits in length or other memorized secret meeting the requirements of Section 5.1.1.2 and SHALL be rate limited as specified in Section 5.2.2. A biometric activation factor SHALL meet the requirements of Section 5.2.3, including limits on the number of consecutive authentication failures.

The unencrypted key and activation secret or biometric sample — and any biometric data derived from the biometric sample such as a probe produced through signal processing — SHALL be zeroized immediately after an authentication transaction has taken place.

5.1.9.2 Multi-Factor Cryptographic Device Verifiers

The requirements for a multi-factor cryptographic device verifier are identical to those for a single-factor cryptographic device verifier, described in Section 5.1.7.2. Verification of the authenticator output from a multi-factor cryptographic device proves use of the activation factor.

5.2 General Authenticator Requirements

5.2.1 Physical Authenticators

CSPs SHALL provide subscriber instructions on how to appropriately protect the authenticator against theft or loss. The CSP SHALL provide a mechanism to revoke or suspend the authenticator immediately upon notification from subscriber that loss or theft of the authenticator is suspected.

5.2.2 Rate Limiting (Throttling)

When required by the authenticator type descriptions in Section 5.1, the verifier SHALL implement controls to protect against online guessing attacks. Unless otherwise specified in the description of a given authenticator, the verifier SHALL limit consecutive failed authentication attempts on a single account to no more than 100.

Additional techniques MAY be used to reduce the likelihood that an attacker will lock the legitimate claimant out as a result of rate limiting. These include:

- Requiring the claimant to complete a CAPTCHA before attempting authentication.

- Requiring the claimant to wait following a failed attempt for a period of time that increases as the account approaches its maximum allowance for consecutive failed attempts (e.g., 30 seconds up to an hour).

- Accepting only authentication requests that come from a white list of IP addresses from which the subscriber has been successfully authenticated before.

- Leveraging other risk-based or adaptive authentication techniques to identify user behavior that falls within, or out of, typical norms. These might, for example, include use of IP address, geolocation, timing of request patterns, or browser metadata.

When the subscriber successfully authenticates, the verifier SHOULD disregard any previous failed attempts for that user from the same IP address.

5.2.3 Use of Biometrics

The use of biometrics (*something you are*) in authentication includes both measurement of physical characteristics (e.g., fingerprint, iris, facial characteristics) and behavioral characteristics (e.g., typing cadence). Both classes are considered biometric modalities, although different modalities may differ in the extent to which they establish authentication intent as described in Section 5.2.9.

For a variety of reasons, this document supports only limited use of biometrics for authentication. These reasons include:

- The biometric False Match Rate (FMR) does not provide confidence in the authentication of the subscriber by itself. In addition, FMR does not account for spoofing attacks.
- Biometric comparison is probabilistic, whereas the other authentication factors are deterministic.
- Biometric template protection schemes provide a method for revoking biometric credentials that is comparable to other authentication factors (e.g., PKI certificates and passwords). However,

the availability of such solutions is limited, and standards for testing these methods are under development.
- Biometric characteristics do not constitute secrets. They can be obtained online or by taking a picture of someone with a camera phone (e.g., facial images) with or without their knowledge, lifted from objects someone touches (e.g., latent fingerprints), or captured with high resolution images (e.g., iris patterns). While presentation attack detection (PAD) technologies (e.g., liveness detection) can mitigate the risk of these types of attacks, additional trust in the sensor or biometric processing is required to ensure that PAD is operating in accordance with the needs of the CSP and the subscriber.

Therefore, the limited use of biometrics for authentication is supported with the following requirements and guidelines:

Biometrics SHALL be used only as part of multi-factor authentication with a physical authenticator (*something you have*).

An authenticated protected channel between sensor (or an endpoint containing a sensor that resists sensor replacement) and verifier SHALL be established and the sensor or endpoint SHALL be authenticated prior to capturing the biometric sample from the claimant.

The biometric system SHALL operate with an FMR [ISO/IEC 2382-37] of 1 in 1000 or better. This FMR SHALL be achieved under conditions of a conformant attack (i.e., zero-effort impostor attempt) as defined in [ISO/IEC 30107-1].

The biometric system SHOULD implement PAD. Testing of the biometric system to be deployed SHOULD demonstrate at least 90% resistance to presentation attacks for each relevant attack type (i.e., species), where resistance is defined as the number of thwarted presentation attacks divided by the number of trial presentation attacks. Testing of presentation attack resistance SHALL be in accordance with Clause 12 of [ISO/IEC 30107-3]. The PAD decision MAY be made either locally on the claimant's device or by a central verifier.

Note: PAD is being considered as a mandatory requirement in future editions of this guideline.

The biometric system SHALL allow no more than 5 consecutive failed authentication attempts or 10 consecutive failed attempts if PAD meeting the above requirements is implemented. Once that limit has been reached, the biometric authenticator SHALL either:

- Impose a delay of at least 30 seconds before the next attempt, increasing exponentially with each successive attempt (e.g., 1 minute before the following failed attempt, 2 minutes before the second following attempt), or
- Disable the biometric user authentication and offer another factor (e.g., a different biometric modality or a PIN/Passcode if it is not already a required factor) if such an alternative method is already available.

The verifier SHALL make a determination of sensor and endpoint performance, integrity, and authenticity. Acceptable methods for making this determination include, but are not limited to:

* Authentication of the sensor or endpoint.
* Certification by an approved accreditation authority.
* Runtime interrogation of signed metadata (e.g., attestation) as described in Section 5.2.4.

Biometric comparison can be performed locally on claimant's device or at a central verifier.

Since the potential for attacks on a larger scale is greater at central verifiers, local comparison is preferred.

If comparison is performed centrally:

* Use of the biometric as an authentication factor SHALL be limited to one or more specific devices that are identified using approved cryptography. Since the biometric has not yet unlocked the main authentication key, a separate key SHALL be used for identifying the device.
* Biometric revocation, referred to as biometric template protection in ISO/IEC 24745, SHALL be implemented.
* All transmission of biometrics SHALL be over the authenticated protected channel.

Biometric samples collected in the authentication process MAY be used to train comparison algorithms or — with user consent — for other research purposes. Biometric samples and any biometric data derived from the biometric sample such as a probe produced through signal processing SHALL be zeroized immediately after any training or research data has been derived.

Biometrics are also used in some cases to prevent repudiation of enrollment and to verify that the same individual participates in all phases of the enrollment process as described in SP 800-63A.

5.2.4 Attestation

An attestation is information conveyed to the verifier regarding a directly-connected authenticator or the endpoint involved in an authentication operation. Information conveyed by attestation MAY include, but is not limited to:

* The provenance (e.g., manufacturer or supplier certification), health, and integrity of the authenticator and endpoint.
* Security features of the authenticator.
* Security and performance characteristics of biometric sensor(s).
* Sensor modality.

If this attestation is signed, it SHALL be signed using a digital signature that provides at least the minimum security strength specified in the latest revision of SP 800-131A (112 bits as of the date of this publication).

Attestation information MAY be used as part of a verifier's risk-based authentication decision.

5.2.5 Verifier Impersonation Resistance

Verifier impersonation attacks, sometimes referred to as "phishing attacks," are attempts by fraudulent verifiers and RPs to fool an unwary claimant into authenticating to an impostor website. In prior versions of SP 800-63, protocols resistant to verifier-impersonation attacks were also referred to as "strongly MitM resistant."

A verifier impersonation-resistant authentication protocol SHALL establish an authenticated protected channel with the verifier. It SHALL then strongly and irreversibly bind a channel identifier that was negotiated in establishing the authenticated protected channel to the authenticator output (e.g., by signing the two values together using a private key controlled by the claimant for which the public key is known to the verifier). The verifier SHALL validate the signature or other information used to prove verifier impersonation resistance. This prevents an

impostor verifier, even one that has obtained a certificate representing the actual verifier, from replaying that authentication on a different authenticated protected channel.

Approved cryptographic algorithms SHALL be used to establish verifier impersonation resistance where it is required. Keys used for this purpose SHALL provide at least the minimum security strength specified in the latest revision of SP 800-131A (112 bits as of the date of this publication).

One example of a verifier impersonation-resistant authentication protocol is client-authenticated TLS, because the client signs the authenticator output along with earlier messages from the protocol that are unique to the particular TLS connection being negotiated.

Authenticators that involve the manual entry of an authenticator output, such as out-of-band and OTP authenticators, SHALL NOT be considered verifier impersonation-resistant because the manual entry does not bind the authenticator output to the specific session being authenticated. In a MitM attack, an impostor verifier could replay the OTP authenticator output to the verifier and successfully authenticate.

5.2.6 Verifier-CSP Communications

In situations where the verifier and CSP are separate entities (as shown by the dotted line in SP 800-63-3 Figure 4-1), communications between the verifier and CSP SHALL occur through a mutually-authenticated secure channel (such as a client-authenticated TLS connection) using approved cryptography.

5.2.7 Verifier-Compromise Resistance

Use of some types of authenticators requires that the verifier store a copy of the authenticator secret. For example, an OTP authenticator (described in Section 5.1.4) requires that the verifier independently generate the authenticator output for comparison against the value sent by the claimant. Because of the potential for the verifier to be compromised and stored secrets stolen, authentication protocols that do not require the verifier to persistently store secrets that could be used for authentication are considered stronger, and are described herein as being *verifier compromise resistant*. Note that such verifiers are not resistant to all attacks. A verifier could be compromised in a different way, such as being manipulated into always accepting a particular authenticator output.

Verifier compromise resistance can be achieved in different ways, for example:

- Use a cryptographic authenticator that requires the verifier store a public key corresponding to a private key held by the authenticator.

- Store the expected authenticator output in hashed form. This method can be used with some look-up secret authenticators (described in Section 5.1.2), for example.

To be considered verifier compromise resistant, public keys stored by the verifier SHALL be associated with the use of approved cryptographic algorithms and SHALL provide at least the minimum security strength specified in the latest revision of SP 800-131A (112 bits as of the date of this publication).

Other verifier compromise resistant secrets SHALL use approved hash algorithms and the underlying secrets SHALL have at least the minimum security strength specified in the latest

revision of SP 800-131A (112 bits as of the date of this publication). Secrets (e.g., memorized secrets) having lower complexity SHALL NOT be considered verifier compromise resistant when hashed because of the potential to defeat the hashing process through dictionary lookup or exhaustive search.

5.2.8 Replay Resistance

An authentication process resists replay attacks if it is impractical to achieve a successful authentication by recording and replaying a previous authentication message. Replay resistance is in addition to the replay-resistant nature of authenticated protected channel protocols, since the output could be stolen prior to entry into the protected channel. Protocols that use nonces or challenges to prove the "freshness" of the transaction are resistant to replay attacks since the verifier will easily detect when old protocol messages are replayed since they will not contain the appropriate nonces or timeliness data.

Examples of replay-resistant authenticators are OTP devices, cryptographic authenticators, and look-up secrets.

In contrast, memorized secrets are not considered replay resistant because the authenticator output — the secret itself — is provided for each authentication.

5.2.9 Authentication Intent

An authentication process demonstrates intent if it requires the subject to explicitly respond to each authentication or reauthentication request. The goal of authentication intent is to make it more difficult for directly-connected physical authenticators (e.g., multi-factor cryptographic devices) to be used without the subject's knowledge, such as by malware on the endpoint. Authentication intent SHALL be established by the authenticator itself, although multi-factor cryptographic devices MAY establish intent by reentry of the other authentication factor on the endpoint with which the authenticator is used.

Authentication intent MAY be established in a number of ways. Authentication processes that require the subject's intervention (e.g., a claimant entering an authenticator output from an OTP device) establish intent. Cryptographic devices that require user action (e.g., pushing a button or reinsertion) for each authentication or reauthentication operation are also establish intent.

Depending on the modality, presentation of a biometric may or may not establish authentication intent. Presentation of a fingerprint would normally establish intent, while observation of the claimant's face using a camera normally would not by itself. Behavioral biometrics similarly are less likely to establish authentication intent because they do not always require a specific action on the claimant's part.

5.2.10 Restricted Authenticators

As threats evolve, authenticators' capability to resist attacks typically degrades. Conversely, some authenticators' performance may improve — for example, when changes to their underlying standards increases their ability to resist particular attacks.

To account for these changes in authenticator performance, NIST places additional restrictions on authenticator types or specific classes or instantiations of an authenticator type.

The use of a RESTRICTED authenticator requires that the implementing organization assess, understand, and accept the risks associated with that RESTRICTED authenticator and acknowledge that risk will likely increase over time. It is the responsibility of the organization to determine the level of acceptable risk for their system(s) and associated data and to define any methods for mitigating excessive risks. If at any time the organization determines that the risk to any party is unacceptable, then that authenticator SHALL NOT be used.

Further, the risk of an authentication error is typically borne by multiple parties, including the implementing organization, organizations that rely on the authentication decision, and the subscriber. Because the subscriber may be exposed to additional risk when an organization accepts a RESTRICTED authenticator and that the subscriber may have a limited understanding of and ability to control that risk, the CSP SHALL:

1. Offer subscribers at least one alternate authenticator that is not RESTRICTED and can be used to authenticate at the required AAL.

2. Provide meaningful notice to subscribers regarding the security risks of the RESTRICTED authenticator and availability of alternative(s) that are not RESTRICTED.

3. Address any additional risk to subscribers in its risk assessment.

4. Develop a migration plan for the possibility that the RESTRICTED authenticator is no longer acceptable at some point in the future and include this migration plan in its digital identity acceptance statement.

7 Session Management

This section is normative.

Once an authentication event has taken place, it is often desirable to allow the subscriber to continue using the application across multiple subsequent interactions without requiring them to repeat the authentication event. This requirement is particularly true for federation scenarios — described in SP 800-63C — where the authentication event necessarily involves several components and parties coordinating across a network.

To facilitate this behavior, a *session* MAY be started in response to an authentication event, and continue the session until such time that it is terminated. The session MAY be terminated for any number of reasons, including but not limited to an inactivity timeout, an explicit logout event, or other means. The session MAY be continued through a reauthentication event — described in Section 7.2 — wherein the user repeats some or all of the initial authentication event, thereby re-establishing the session.

Session management is preferable over continual presentation of credentials as the poor usability of continual presentation often creates incentives for workarounds such as cached unlocking credentials, negating the freshness of the authentication event.

7.1 Session Bindings

A session occurs between the software that a subscriber is running — such as a browser, application, or operating system (i.e., the session subject) — and the RP or CSP that the subscriber is accessing (i.e., the session host). A session secret SHALL be shared between the subscriber's software and the service being accessed. This secret binds the two ends of the

session, allowing the subscriber to continue using the service over time. The secret SHALL be presented directly by the subscriber's software or possession of the secret SHALL be proven using a cryptographic mechanism.

The secret used for session binding SHALL be generated by the session host in direct response to an authentication event. A session SHOULD inherit the AAL properties of the authentication event which triggered its creation. A session MAY be considered at a lower AAL than the authentication event but SHALL NOT be considered at a higher AAL than the authentication event.

Secrets used for session binding:

1. SHALL be generated by the session host during an interaction, typically immediately following authentication. 2. SHALL be generated by an approved random bit generator [SP 800-90Ar1] and contain at least 64 bits of entropy. 3. SHALL be erased or invalidated by the session subject when the subscriber logs out. 4. SHOULD be erased on the subscriber endpoint when the user logs out or when the secret is deemed to have expired. 5. SHOULD NOT be placed in insecure locations such as HTML5 Local Storage due to the potential exposure of local storage to cross-site scripting (XSS) attacks. 6. SHALL be sent to and received from the device using an authenticated protected channel. 7. SHALL time out and not be accepted after the times specified in Sections 4.1.4, 4.2.4, and 4.3.4, as appropriate for the AAL. 8. SHALL NOT be available to insecure communications between the host and subscriber's endpoint. Authenticated sessions SHALL NOT fall back to an insecure transport, such as from https to http, following authentication.

URLs or POST content SHALL contain a session identifier that SHALL be verified by the RP to ensure that actions taken outside the session do not affect the protected session.

There are several mechanisms for managing a session over time. The following sections give different examples along with additional requirements and considerations particular to each example technology. Additional informative guidance is available in the OWASP *Session Management Cheat Sheet* [OWASP-session].

7.1.1 Browser Cookies

Browser cookies are the predominant mechanism by which a session will be created and tracked for a subscriber accessing a service.

Cookies:

1. SHALL be tagged to be accessible only on secure (HTTPS) sessions. 2. SHALL be accessible to the minimum practical set of hostnames and paths. 3. SHOULD be tagged to be inaccessible via JavaScript (HttpOnly). 4. SHOULD be tagged to expire at, or soon after, the session's validity period. This requirement is intended to limit the accumulation of cookies, but SHALL NOT be depended upon to enforce session timeouts.

7.1.2 Access Tokens

An access token — such as found in OAuth — is used to allow an application to access a set of services on a subscriber's behalf following an authentication event. The presence of an OAuth access token SHALL NOT be interpreted by the RP as presence of the subscriber, in the absence of other signals. The OAuth access token, and any associated refresh tokens, MAY be valid long after the authentication session has ended and the subscriber has left the application.

7.1.3 Device Identification

Other methods of secure device identification — including but not limited to mutual TLS, token binding, or other mechanisms — MAY be used to enact a session between a subscriber and a service.

7.2 Reauthentication

Continuity of authenticated sessions SHALL be based upon the possession of a session secret issued by the verifier at the time of authentication and optionally refreshed during the session. The nature of a session depends on the application, including:

1. A web browser session with a "session" cookie, or 2. An instance of a mobile application that retains a session secret.

Session secrets SHALL be non-persistent. That is, they SHALL NOT be retained across a restart of the associated application or a reboot of the host device.

Periodic reauthentication of sessions SHALL be performed to confirm the continued presence of the subscriber at an authenticated session (i.e., that the subscriber has not walked away without logging out).

A session SHALL NOT be extended past the guidelines in Sections 4.1.3, 4.2.3, and 4.3.3 (depending on AAL) based on presentation of the session secret alone. Prior to session expiration, the reauthentication time limit SHALL be extended by prompting the subscriber for the authentication factor(s) specified in Table 7-1.

When a session has been terminated, due to a time-out or other action, the user SHALL be required to establish a new session by authenticating again.

Table 7-1 AAL Reauthentication Requirements

|AAL|Requirement|

1	Presentation of any one factor
2	Presentation of a memorized secret or biometric
3	Presentation of all factors

Note: At AAL2, a memorized secret or biometric, and not a physical authenticator, is required because the session secret is *something you have*, and an additional authentication factor is required to continue the session.

7.2.1 Reauthentication from a Federation or Assertion

When using a federation protocol as described in SP 800-63C, Section 5 to connect the CSP and RP, special considerations apply to session management and reauthentication. The federation protocol communicates an authentication event between the CSP and the RP but establishes no session between them. Since the CSP and RP often employ separate session management technologies, there SHALL NOT be any assumption of correlation between these sessions. Consequently, when an RP session expires and the RP requires reauthentication, it is entirely possible that the session at the CSP has not expired and that a new assertion could be generated from this session at the CSP without reauthenticating the user.

An RP requiring reauthentication through a federation protocol SHALL — if possible within the protocol — specify the maximum acceptable authentication age to the CSP, and the CSP SHALL reauthenticate the subscriber if they have not been authenticated within that time period. The CSP SHALL communicate the authentication event time to the RP to allow the RP to decide if the assertion is sufficient for reauthentication and to determine the time for the next reauthentication event.

Appendix A—Strength of Memorized Secrets

This appendix is informative.

Throughout this appendix, the word "password" is used for ease of discussion. Where used, it should be interpreted to include passphrases and PINs as well as passwords.

A.1 Introduction

Despite widespread frustration with the use of passwords from both a usability and security standpoint, they remain a very widely used form of authentication [Persistence]. Humans, however, have only a limited ability to memorize complex, arbitrary secrets, so they often choose passwords that can be easily guessed. To address the resultant security concerns, online services have introduced rules in an effort to increase the complexity of these memorized secrets. The most notable form of these is composition rules, which require the user to choose passwords constructed using a mix of character types, such as at least one digit, uppercase letter, and symbol. However, analyses of breached password databases reveal that the benefit of such rules is not nearly as significant as initially thought [Policies], although the impact on usability and memorability is severe.

Complexity of user-chosen passwords has often been characterized using the information theory concept of entropy [Shannon]. While entropy can be readily calculated for data having deterministic distribution functions, estimating the entropy for user-chosen passwords is difficult and past efforts to do so have not been particularly accurate. For this reason, a different and somewhat simpler approach, based primarily on password length, is presented herein.

Many attacks associated with the use of passwords are not affected by password complexity and length. Keystroke logging, phishing, and social engineering attacks are equally effective on lengthy, complex passwords as simple ones. These attacks are outside the scope of this Appendix.

A.2 Length

Password length has been found to be a primary factor in characterizing password strength [Strength] [Composition]. Passwords that are too short yield to brute force attacks as well as to dictionary attacks using words and commonly chosen passwords.

The minimum password length that should be required depends to a large extent on the threat model being addressed. Online attacks where the attacker attempts to log in by guessing the password can be mitigated by limiting the rate of login attempts permitted. In order to prevent an attacker (or a persistent claimant with poor typing skills) from easily inflicting a denial-of-service attack on the subscriber by making many incorrect guesses, passwords need to be complex enough that rate limiting does not occur after a modest number of erroneous attempts, but does occur before there is a significant chance of a successful guess.

Offline attacks are sometimes possible when one or more hashed passwords is obtained by the attacker through a database breach. The ability of the attacker to determine one or more users' passwords depends on the way in which the password is stored. Commonly, passwords are salted with a random value and hashed, preferably using a computationally expensive algorithm. Even with such measures, the current ability of attackers to compute many billions of hashes per second with no rate limiting requires passwords intended to resist such attacks to be orders of magnitude more complex than those that are expected to resist only online attacks.

Users should be encouraged to make their passwords as lengthy as they want, within reason. Since the size of a hashed password is independent of its length, there is no reason not to permit the use of lengthy passwords (or pass phrases) if the user wishes. Extremely long passwords (perhaps megabytes in length) could conceivably require excessive processing time to hash, so it is reasonable to have some limit.

A.3 Complexity

As noted above, composition rules are commonly used in an attempt to increase the difficulty of guessing user-chosen passwords. Research has shown, however, that users respond in very predictable ways to the requirements imposed by composition rules [Policies]. For example, a user that might have chosen "password" as their password would be relatively likely to choose "Password1" if required to include an uppercase letter and a number, or "Password1!" if a symbol is also required.

Users also express frustration when attempts to create complex passwords are rejected by online services. Many services reject passwords with spaces and various special characters. In some cases, the special characters that are not accepted might be an effort to avoid attacks like SQL injection that depend on those characters. But a properly hashed password would not be sent intact to a database in any case, so such precautions are unnecessary. Users should also be able to include space characters to allow the use of phrases. Spaces themselves, however, add little to the complexity of passwords and may introduce usability issues (e.g., the undetected use of two spaces rather than one), so it may be beneficial to remove repeated spaces in typed passwords prior to verification.

Users' password choices are very predictable, so attackers are likely to guess passwords that have been successful in the past. These include dictionary words and passwords from previous breaches, such as the "Password1!" example above. For this reason, it is recommended that passwords chosen by users be compared against a "black list" of unacceptable passwords. This list should include passwords from previous breach corpuses, dictionary words, and specific words (such as the name of the service itself) that users are likely to choose. Since user choice of passwords will also be governed by a minimum length requirement, this dictionary need only include entries meeting that requirement.

Highly complex memorized secrets introduce a new potential vulnerability: they are less likely to be memorable, and it is more likely that they will be written down or stored electronically in an unsafe manner. While these practices are not necessarily vulnerable, statistically some methods of recording such secrets will be. This is an additional motivation not to require excessively long or complex memorized secrets.

A.4 Randomly-Chosen Secrets

Another factor that determines the strength of memorized secrets is the process by which they

are generated. Secrets that are randomly chosen (in most cases by the verifier or CSP) and are uniformly distributed will be more difficult to guess or brute-force attack than user-chosen secrets meeting the same length and complexity requirements. Accordingly, at LOA2, SP 800-63-2 permitted the use of randomly generated PINs with 6 or more digits while requiring user-chosen memorized secrets to be a minimum of 8 characters long.

As discussed above, the threat model being addressed with memorized secret length requirements includes rate-limited online attacks, but not offline attacks. With this limitation, 6 digit randomly-generated PINs are still considered adequate for memorized secrets.

A.5 Summary

Length and complexity requirements beyond those recommended here significantly increase the difficulty of memorized secrets and increase user frustration. As a result, users often work around these restrictions in a way that is counterproductive. Furthermore, other mitigations such as blacklists, secure hashed storage, and rate limiting are more effective at preventing modern brute-force attacks. Therefore, no additional complexity requirements are imposed.